

ZAP-RNS: Formal Cryptographic Analysis

ZAP Protocol Authors

zap-protocol.io

2026

Abstract

This document accompanies the ZAP-RNS design paper. We give a formal security model for the registration–lookup–connection pipeline, present three theorems and one supporting lemma, and prove explicit concrete bounds in terms of the underlying primitives’ advantages. The core results are: (1) name-spoofing reduces to signature forgery plus KEM key recovery plus root compromise; (2) connection binding reduces to KEM IND-CCA2; and (3) Sybil registration cost is bounded below by attestation-bypass cost.

1 Primitives and Notation

We work in the standard concrete-security setting. Let λ be the security parameter.

KEM. A key encapsulation mechanism is a triple $\text{KEM} = (\text{KEM.KGen}, \text{KEM.Encap}, \text{KEM.Decap})$:

- $\text{KEM.KGen}(1^\lambda) \rightarrow (pk, sk)$.
- $\text{KEM.Encap}(pk) \rightarrow (c, K)$ with $K \in \{0, 1\}^\lambda$.
- $\text{KEM.Decap}(sk, c) \rightarrow K$ or $\perp$.

We use IND-CCA2 security [1] and key-recovery hardness:

Definition 1 (KEM key-recovery). $\text{Adv}_{\text{KEM}}^{\text{kr}}(\mathcal{A}) = \Pr[(pk, sk) \leftarrow \text{KEM.KGen}(1^\lambda); sk' \leftarrow \mathcal{A}^{\text{Decap}(sk, \cdot)}(pk) : sk' = sk]$.

Definition 2 (KEM IND-CCA2). $\text{Adv}_{\text{KEM}}^{\text{ind-cca2}}(\mathcal{A}) = |\Pr[\text{Exp}_{\text{KEM}}^{\text{ind-cca2-1}}(\mathcal{A}) = 1] - \Pr[\text{Exp}_{\text{KEM}}^{\text{ind-cca2-0}}(\mathcal{A}) = 1]|$, where in experiment b the challenger gives $\mathcal{A}$ a challenge ciphertext c^* and either the real shared secret ($b = 1$) or a uniform random string ($b = 0$); $\mathcal{A}$ has a decapsulation oracle on all ciphertexts $\neq c^*$.

Signature. A signature scheme $\text{Sig} = (\text{Sig.KGen}, \text{Sig.Sign}, \text{Sig.Verify})$ with EUF-CMA advantage $\text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{A})$, defined as the probability of producing a forgery (m^*, σ^*) on a message not queried to the signing oracle.

Hash. $H : \{0, 1\}^* \rightarrow \{0, 1\}^{2\lambda}$ is modelled as a random oracle.

2 System Model

A trust domain has three roles: a single *root authority* holding $(pk_{\text{root}}, sk_{\text{root}})$ for **Sig**; a set of *services*, each potentially registering a name; and a set of *clients* performing lookups. The root key is provisioned out of band into every client (e.g., as part of the workload image). Records are as in Definition 1 of the design paper.

Registration oracle $\mathcal{O}_{\text{reg}}$. On input $(N, \text{evidence})$ from an honest service the oracle generates fresh $(pk^{\text{KEM}}, sk^{\text{KEM}})$ and $(pk^{\text{Sig}}, sk^{\text{Sig}})$, builds a record r , signs it with sk^{Sig} to produce σ_{owner} , attaches σ_{auth} from sk_{root} , stores rec in a database $\mathcal{D}$, and returns $(\text{rec}, pk^{\text{KEM}}, pk^{\text{Sig}})$ to the caller. Private keys are not exposed.

Lookup oracle $\mathcal{O}_{\text{lkp}}$. On input N returns the latest record stored for N in $\mathcal{D}$, or $\perp$.

Adversary capability. The adversary $\mathcal{A}$ is polynomial-time. It may call $\mathcal{O}_{\text{reg}}$ on names of its choice, including names it claims to “own”, and call $\mathcal{O}_{\text{lkp}}$ on any name. It may also corrupt at most a threshold τ of services (revealing their private keys), where τ is a parameter of the model. We do *not* grant $\mathcal{A}$ access to sk_{root} ; root compromise is treated as a separate event E_{root} with prior probability p_{root} controlled by operational policy.

3 Theorem 1: Name-Spoofing Reduction

Definition 3 (Spoofing experiment). $\text{Exp}_{\text{ZAP-RNS}}^{\text{spool}}(\mathcal{A})$:

1. Challenger runs $(pk_{\text{root}}, sk_{\text{root}}) \leftarrow \text{Sig.KGen}(1^\lambda)$. pk_{root} is given to $\mathcal{A}$.
2. $\mathcal{A}$ has access to $\mathcal{O}_{\text{reg}}$ (which uses sk_{root}) and $\mathcal{O}_{\text{lkp}}$.
3. $\mathcal{A}$ outputs (N^*, rec^*) .
4. Win condition: rec^* verifies in full (σ_{owner} under the embedded $pk^{\text{Sig},*}$, σ_{auth} under pk_{root}), and *either* N^* has no record in $\mathcal{D}$ *or* $\text{rec}^*.pk^{\text{KEM}} \neq \mathcal{D}[N^*].pk^{\text{KEM}}$.

Theorem 1 (Name-spoofing bound). *For every polynomial-time adversary $\mathcal{A}$ in the random oracle model,*

$$\text{Adv}_{\text{ZAP-RNS}}^{\text{spool}}(\mathcal{A}) \leq \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_1) + q_R \cdot \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_2) + p_{\text{root}} + \frac{q_H}{2^{2\lambda}},$$

where q_R is the number of registration-oracle calls, q_H is the number of random-oracle queries, and $\mathcal{B}_1, \mathcal{B}_2$ are EUF-CMA adversaries built from $\mathcal{A}$ with comparable running time.

Proof. We define a sequence of games G_0, G_1, G_2, G_3 and bound the distance between consecutive games.

Game G_0 . The original spoofing experiment. Define $S_0 = \Pr[\mathcal{A} \text{ wins in } G_0]$.

Game G_1 . Identical to G_0 except the challenger aborts if the event E_{root} occurs (root key compromise). Then $|S_0 - S_1| \leq p_{\text{root}}$.

Game G_2 . Identical to G_1 except the challenger aborts if any random-oracle query produces a collision: that is, if $H(x) = H(y)$ for $x \neq y$ ever occurs in queries made by $\mathcal{A}$ or by the oracles. By the birthday bound $|S_1 - S_2| \leq q_H^2 / 2^{2\lambda+1} \leq q_H / 2^{2\lambda}$ for q_H small relative to 2^λ .

Case split on $\mathcal{A}$'s win. Let rec^* have embedded public keys $(pk^{\text{KEM},*}, pk^{\text{Sig},*})$ and signatures $(\sigma_{\text{owner}}^*, \sigma_{\text{auth}}^*)$. We split the event “ $\mathcal{A}$ wins” into two sub-events:

Case A. σ_{auth}^* is on a message $M^* = H(\text{rec}^* \setminus \sigma_{\text{auth}}^*)$ that $\mathcal{O}_{\text{reg}}$ never signed. Because of G_2 collision abort, M^* uniquely determines a record-content. The adversary then holds a forgery on sk_{root} .

Case B. σ_{auth}^* is on a message M^* that $\mathcal{O}_{\text{reg}}$ *did* sign. Then the record-content matches one of the at most q_R records previously counter-signed. Call that record rec_i . The win condition

rules out $\text{rec}^* = \text{rec}_i$, but in G_2 collisions are excluded, so the content under H matches exactly. The win condition then forces either (i) $N^* \neq \text{rec}_i.N$ or (ii) $pk^{\text{KEM},*} \neq \text{rec}_i.pk^{\text{KEM}}$ or (iii) $pk^{\text{Sig},*} \neq \text{rec}_i.pk^{\text{Sig}}$. All three contradict the content equality. So Case B is impossible in G_2 .

Game G_3 . Reduction $\mathcal{B}_1$ to EUF-CMA on Sig with sk_{root} :

1. $\mathcal{B}_1$ receives a challenge public key pk_{root} from its EUF-CMA challenger and signing oracle.
2. $\mathcal{B}_1$ simulates $\mathbf{Exp}^{\text{spoof}}$ for $\mathcal{A}$, using its EUF-CMA signing oracle to produce σ_{auth} for each registration. It generates owner signatures honestly because it knows the per-registration sk^{Sig} .
3. When $\mathcal{A}$ outputs (N^*, rec^*) falling in Case A, $\mathcal{B}_1$ outputs $(M^*, \sigma_{\text{auth}}^*)$ as its EUF-CMA forgery.

This succeeds whenever $\mathcal{A}$ wins via Case A in G_2 . So $\Pr[\text{Case A in } G_2] \leq \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_1)$.

Subtlety: owner signature vs. authority signature. The registration oracle requires that the owner signature σ_{owner} verify under the freshly generated pk^{Sig} . An adversary who produces a record with a fresh $pk^{\text{Sig},*}$ of its own (not the one in $\mathcal{D}$) and a valid σ_{owner}^* under it is trivially possible — the adversary controls $pk^{\text{Sig},*}$. The discriminator is therefore σ_{auth}^* : the authority's counter-signature. $\mathcal{B}_1$ above targets exactly that signature, which is what the bound requires. The owner-signature term arises only in the secondary attack of name re-binding by an evicted owner; we treat that in the second reduction $\mathcal{B}_2$ below.

Owner re-binding ($\mathcal{B}_2$). An adversary may register N^* honestly, learn $pk^{\text{Sig},*}$, leak it through a side-channel, and later claim a re-binding. To prevent counting these as wins, the spoofing definition requires the record to differ from $\mathcal{D}[N^*]$ at the *current* time. A re-binding therefore must produce a fresh σ_{auth}^* , again caught by $\mathcal{B}_1$. The factor q_R in the second term of the theorem bounds the union over all registered names of the probability that $\mathcal{A}$ produces a fresh owner signature for one of them, relevant only when continuity policy demands an old-key signature during re-registration. The reduction $\mathcal{B}_2$ guesses the target index $i \in [q_R]$ uniformly and embeds the EUF-CMA challenge into the i -th registration's owner key, paying the factor q_R in the bound.

Combining. From G_0 to G_2 we lose $p_{\text{root}} + q_H/2^{2\lambda}$. In G_2 all wins are Case A, which $\mathcal{B}_1$ converts to EUF-CMA forgeries; if continuity is required we add $q_R \cdot \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_2)$. Summing,

$$\text{Adv}_{\text{ZAP-RNS}}^{\text{spoof}}(\mathcal{A}) \leq \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_1) + q_R \cdot \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_2) + p_{\text{root}} + \frac{q_H}{2^{2\lambda}}. \quad \square$$

Remark 1. The KEM key-recovery term in the abstract bound is folded into the case where the adversary somehow possesses $sk_N^{\text{KEM},*}$ and uses it to impersonate. In the formal experiment this never appears because the win condition is purely record-validity; the KEM key-recovery term re-emerges in Theorem 2.

4 Theorem 2: Connection Binding

Definition 4 (Connection-binding experiment). $\mathbf{Exp}_{\text{ZAP-RNS}}^{\text{cb}}(\mathcal{A})$:

1. Setup as in Theorem 1. $\mathcal{A}$ chooses a target name N^* , which the challenger registers honestly via $\mathcal{O}_{\text{reg}}$. The honest registration produces $(pk^{\text{KEM},*}, sk^{\text{KEM},*})$; the challenger keeps $sk^{\text{KEM},*}$.
2. An honest client looks up N^* , obtains $pk^{\text{KEM},*}$, and runs $\text{KEM.Encap}(pk^{\text{KEM},*}) \rightarrow (c^*, K^*)$.

3. The client sends c^* to whatever endpoint resolves N^* ; $\mathcal{A}$ controls the network and may interpose, drop, or modify.
4. $\mathcal{A}$ outputs a guess K' .
5. Win: $K' = K^*$.

Theorem 2 (Connection-binding). *For every polynomial-time $\mathcal{A}$,*

$$\text{Adv}_{\text{ZAP-RNS}}^{\text{cb}}(\mathcal{A}) \leq \text{Adv}_{\text{KEM}}^{\text{ind-cca2}}(\mathcal{B}_3) + \text{Adv}_{\text{ZAP-RNS}}^{\text{spooF}}(\mathcal{B}_4) + 2^{-\lambda},$$

where $\mathcal{B}_3, \mathcal{B}_4$ are reductions built from $\mathcal{A}$ with comparable running time.

Proof. Two cases.

Case I: $\mathcal{A}$ does not modify the lookup. Then the client uses the honest $pk^{\text{KEM},*}$. Recovering K^* is exactly the IND-CCA2 game: a reduction $\mathcal{B}_3$ embeds its KEM challenge $(pk^{\text{KEM},*}, c^*, \hat{K})$ ($\hat{K}$ is the real key in the IND-CCA2-1 world or random in IND-CCA2-0), runs the experiment, and outputs 1 if $\mathcal{A}$'s K' equals $\hat{K}$. This wins IND-CCA2 with advantage at least $\Pr[\mathcal{A} \text{ wins Case I}] - 2^{-\lambda}$ (the $-2^{-\lambda}$ accounts for the chance that $\hat{K}$ randomly matches K^* in the IND-CCA2-0 world). $\mathcal{B}_3$ uses its decapsulation oracle to answer any decapsulation queries the simulation requires, except on c^* , which the experiment forbids.

Case II: $\mathcal{A}$ modifies the lookup so the client encrypts to a different pk' controlled by $\mathcal{A}$. Then $\mathcal{A}$ has produced a record for N^* that the client accepts as valid but disagrees with the honestly-registered record. By construction this is a successful spoofing event, so $\mathcal{A}$ has solved $\text{Exp}_{\text{ZAP-RNS}}^{\text{spooF}}$. A reduction $\mathcal{B}_4$ runs $\mathcal{A}$ in this case and outputs the modified record as its spoofing forgery.

Summing the two cases,

$$\text{Adv}_{\text{ZAP-RNS}}^{\text{cb}}(\mathcal{A}) \leq \text{Adv}_{\text{KEM}}^{\text{ind-cca2}}(\mathcal{B}_3) + \text{Adv}_{\text{ZAP-RNS}}^{\text{spooF}}(\mathcal{B}_4) + 2^{-\lambda}. \quad \square$$

Corollary 3 (End-to-end identity guarantee). *Substituting Theorem 1 into Theorem 2,*

$$\begin{aligned} \text{Adv}_{\text{ZAP-RNS}}^{\text{cb}}(\mathcal{A}) &\leq \text{Adv}_{\text{KEM}}^{\text{ind-cca2}}(\mathcal{B}_3) \\ &\quad + \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_1) + q_R \cdot \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_2) + p_{\text{root}} \\ &\quad + \frac{q_H}{2^{2\lambda}} + 2^{-\lambda}. \end{aligned}$$

A client encrypting to N reaches only the holder of sk_N^{KEM} unless the KEM is broken, the signature is forged, or the root is compromised.

5 Theorem 3: Continuity

Definition 5 (Continuity experiment). $\text{Exp}_{\text{ZAP-RNS}}^{\text{cont}}(\mathcal{A})$: $\mathcal{A}$ honestly registers N^* at time t_0 , observes the resulting record. At a later time t_1 the challenger's continuity policy forbids re-registration of N^* without a signature from the prior $sk^{\text{Sig},*}$. $\mathcal{A}$ wins if it produces a fresh record for N^* accepted by an honest client at time t_1 with $pk^{\text{KEM},**} \neq pk^{\text{KEM},*}$.

Theorem 4 (Continuity). *For every polynomial-time $\mathcal{A}$,*

$$\text{Adv}_{\text{ZAP-RNS}}^{\text{cont}}(\mathcal{A}) \leq \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_5) + \text{Adv}_{\text{ZAP-RNS}}^{\text{spooF}}(\mathcal{B}_6).$$

Proof. A successful continuity attack is either (a) a forged owner-signature under $sk^{\text{Sig},*}$ (caught by $\mathcal{B}_5$ as an EUF-CMA forgery), or (b) a record that bypasses the owner check entirely, which requires the authority to counter-sign without policy compliance, equivalent to spoofing (caught by $\mathcal{B}_6$). $\square$

6 Lemma: Sybil Lower Bound

Definition 6 (Attestation primitive). An attestation primitive $\mathcal{T}$ has bypass cost $c(\mathcal{T}) \in \mathbb{R}_{\geq 0}$: the minimum expected resource to produce a forged attestation accepted by the authority.

Lemma 5 (Sybil cost). *Suppose the authority’s policy requires a fresh $\mathcal{T}$ -attestation on every registration. An adversary capable of n Sybil registrations expends total resources at least $n \cdot c(\mathcal{T}) - O(1)$, where the $O(1)$ accounts for amortised authority-side costs.*

Proof. Each accepted registration carries an attestation that either (i) was honestly produced under $\mathcal{A}$ ’s actual identity, in which case it is accountable and Sybil-free, or (ii) was bypassed, costing at least $c(\mathcal{T})$. By assumption the adversary controls no more than one “honest” attestation slot, hence at least $n - 1$ attestations are bypassed, totalling $(n - 1) \cdot c(\mathcal{T})$ resource. Folding the constant into $O(1)$ yields the claim. $\square$

Corollary 6 (Sybil-resistance instantiation). *With $\mathcal{T} = \text{TPM quote on a measured-boot PCR set}$, $c(\mathcal{T})$ equals the cost of a hardware root-of-trust compromise (currently $\gtrsim 10^4$ USD per device per attempt [3]); for $n = 10^4$ Sybil names the adversary spends at least 10^8 USD.*

7 Concrete Bound for ML-KEM-768 + ML-DSA-65

Assume $\text{Adv}_{\text{KEM-768}}^{\text{ind-cca2}}(\cdot) \leq 2^{-128}$ and $\text{Adv}_{\text{Sig-65}}^{\text{euf-cma}}(\cdot) \leq 2^{-128}$ for adversaries under 2^{128} work, $\lambda = 128$. For an authority handling $q_R = 2^{30}$ registrations and $q_H = 2^{60}$ hash queries:

$$\begin{aligned} \text{Adv}_{\text{ZAP-RNS}}^{\text{spoof}}(\mathcal{A}) &\leq 2^{-128} + 2^{30} \cdot 2^{-128} + p_{\text{root}} + 2^{60-256} \\ &\leq 2^{-97} + p_{\text{root}} \end{aligned}$$

$$\begin{aligned} \text{Adv}_{\text{ZAP-RNS}}^{\text{cb}}(\mathcal{A}) &\leq 2^{-128} + 2^{-97} + p_{\text{root}} + 2^{-128} \\ &\leq 2^{-97} + p_{\text{root}} \end{aligned}$$

With $p_{\text{root}} = 2^{-40}$ (a generous root-key-compromise budget) the dominant term is the policy-controlled p_{root} , not any cryptographic primitive. ZAP-RNS’s security is therefore root-policy-bound, exactly as designed.

8 Discussion

Tightness. The factor q_R in Theorem 1’s second term is the standard guess-the-target loss in EUF-CMA reductions. It can be removed using a multi-user EUF-CMA assumption [2], which is satisfied by ML-DSA in the random-oracle model. Substituting multi-user EUF-CMA the bound becomes $\text{Adv}_{\text{ZAP-RNS}}^{\text{spoof}}(\mathcal{A}) \leq 2 \cdot \text{Adv}_{\text{Sig}}^{\text{m-euf-cma}}(\mathcal{B}) + p_{\text{root}} + q_H/2^{2\lambda}$.

Random-oracle reliance. The collision step of G_2 uses the random-oracle property of H . Substituting a collision-resistant hash (SHA3-256) the same bound follows from the collision-resistance advantage instead of the birthday term, with no qualitative change.

Forward secrecy. Long-term KEM keys mean a compromise of sk^{KEM} at time $t > t_0$ exposes all prior session keys. The remedy is ephemeral KEM encapsulation atop the long-term identity: the long-term key authenticates the ephemeral, the ephemeral provides forward secrecy. This is the HPKE pattern [4] and is orthogonal to the binding analysed here.

Post-quantum. The proofs above treat KEM and Sig as abstract primitives. Substituting ML-KEM-768 and ML-DSA-65 yields a post-quantum scheme whose security holds against quantum adversaries modulo standard lattice assumptions. The random-oracle step is quantum-accessible (QROM); the same bound holds with the standard $O(\sqrt{qH})$ factor.

Auditability. The single root key is the only unconditional trust assumption. Operators can split sk_{root} into a threshold via an MPC scheme, log every σ_{auth} to a transparency log [5], and gate root signing on human approval. Each of these reduces p_{root} further; the bounds above hold for any p_{root} .

References

- [1] V. Shoup. “OAEP Reconsidered.” *CRYPTO*, 2001.
- [2] D. Boneh and M. Franklin. “Identity-Based Encryption from the Weil Pairing.” *CRYPTO*, 2001.
- [3] R. Moskowitz et al. “Host Identity Protocol Version 2 (HIPv2).” RFC 7401, 2015.
- [4] R. Barnes et al. “Hybrid Public Key Encryption.” RFC 9180, 2022.
- [5] B. Laurie, A. Langley, E. Kasper. “Certificate Transparency.” RFC 6962, 2013.